3CX Supply Chain Lab

1. Scenario

A large multinational corporation heavily relies on the 3CX software for phone communication, making it a critical component of their business operations. After a recent update to the 3CX Desktop App, antivirus alerts flag sporadic instances of the software being wiped from some workstations while others remain unaffected. Dismissing this as a false positive, the IT team overlooks the alerts, only to notice degraded performance and strange network traffic to unknown servers. Employees report issues with the 3CX app, and the IT security team identifies unusual communication patterns linked to recent software updates.

As the threat intelligence analyst, it's your responsibility to examine this possible supply chain attack. Your objectives are to uncover how the attackers compromised the 3CX app, identify the potential threat actor involved, and assess the overall extent of the incident.

2. Write up

- 3CX is a software which allows businesses to make calls, video calls and manger communications over the Internet

1. Understanding the scope of the attack and identifying which versions exhibit malicious behavior is crucial for making informed decisions if these compromised versions are present in the organization. How many versions of 3CX **running on Windows** have been flagged as malware?

- As: 2
- I don’t want to upload the MSI file on the Virustotal because I’m afraid of data breach. I use sha256sum to calculate the hash of file
- Hash: 59e1edf4d82fae4978e97512b0331b7eb21dd4b838b850ba46794d9c7a2c0983

```
┌──(moon㉿moon)-[~/soc1/b10/temp_extract_dir]
└─$ sha256sum 3CXDesktopApp-18.12.416.msi
59e1edf4d82fae4978e97512b0331b7eb21dd4b838b850ba46794d9c7a2c0983  3CXDesktopApp-18.12.416.msi

┌──(moon㉿moon)-[~/soc1/b10/temp_extract_dir]
└─$
```

- I search on the Virustotal with the hash and the Collections of Relations Tab links to the URL https://unit42.paloaltonetworks.com/3cxdesktopapp-supply-chain-attack/
    - The post mentions: "According to 3CX's announcement, the supply chain attack involved the 3CX Electron Windows App shipped in Update 7, version numbers 18.12.407 and 18.12.416, and Electron Mac App version numbers 18.11.1213, 18.12.402, 18.12.407 and 18.12.416."
    - So It can be included that there are two versions of 3CX running on Windows

2. Determining the age of the malware can help assess the extent of the compromise and track the evolution of malware families and variants. What's the UTC creation time of the `.msi` malware?

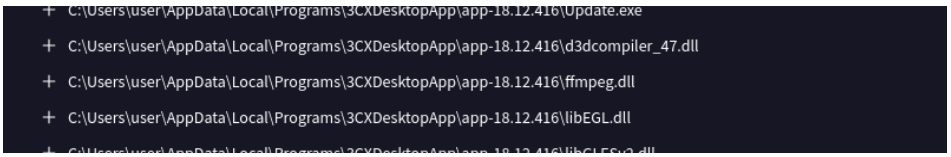
- As: 2023-03-13 06:33
- This malware was created at 2023-03-13 06:33. It's relatively new; therefor, it is essential to prioritize its prevention and elimination

History

Creation Time	2023-03-13 06:33:26 UTC
Signature Date	2023-03-13 06:34:00 UTC
First Seen In The Wild	2023-03-29 21:10:08 UTC
First Submission	2023-03-22 06:39:15 UTC
Last Submission	2026-04-25 14:44:28 UTC
Last Analysis	2026-04-21 04:07:56 UTC

3. Executable files (`.exe`) are frequently used as primary or secondary malware payloads, while dynamic link libraries (`.dll`) often load malicious code or enhance malware functionality. Analyzing files deposited by the Microsoft Software Installer (`.msi`) is crucial for identifying malicious files and investigating their full potential. Which malicious DLLs were dropped by the `.msi` file?

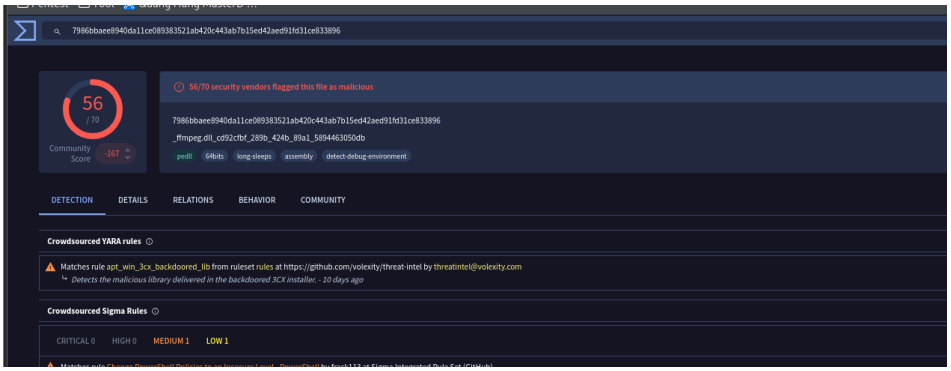
- As: ffmpeg.dll, d3dcompiler_47.dll
- Investigating the msi file's DLL dependencies which load code or enhance functionality can reveal it's full potential.
- I searched into the Files Dropped Tab and found out 2 DLL: ffmpeg.dll, d3dcompiler_47.dll
    - ffmpeg.dll: It handles audio and video processing
    - d3dcompiler_47.dll: It compiles shader (3D graphics) → used in the game, win app (GUI, video render), tool,...
    - Two DLLs are used by 3CX app to implement its functions. However, these file are located in the AppData, which is unusual.

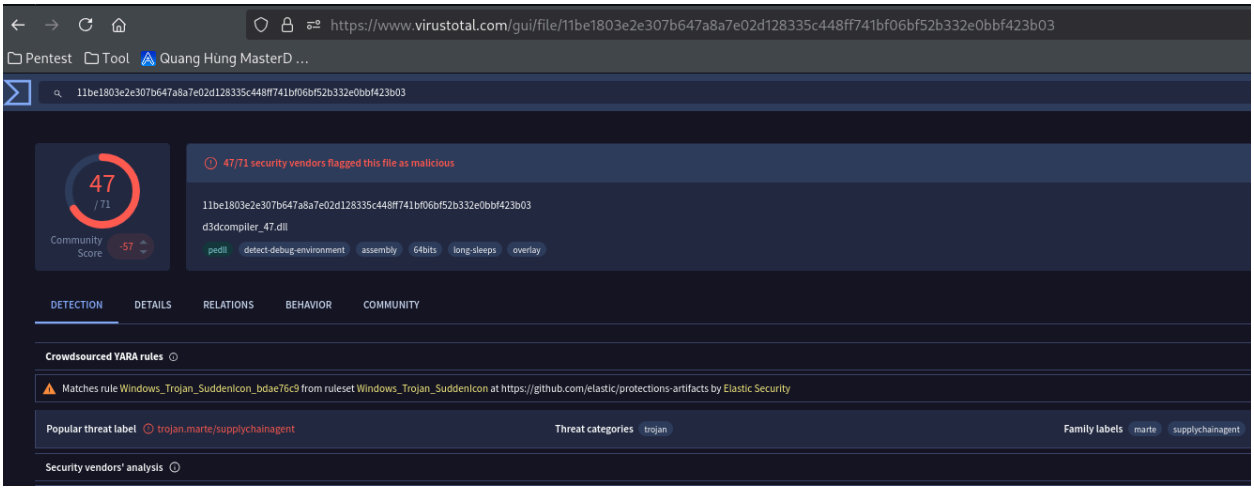


- To prove, I use msiextract tool to extract files in the .msi file and use find tool to find out dll file

./app-18.12.416/libGLESv2.dll
./app-18.12.416/vulkan-1.dll
./app-18.12.416/vk_swiftshader.dll
./app-18.12.416/libEGL.dll
./app-18.12.416/ffmpeg.dll
./app-18.12.416/d3dcompiler_47.dll

- I calculate hash of these files and search on the virustotal, ffmpeg.dll, d3dcompiler_47.dll are proven to be malicious files



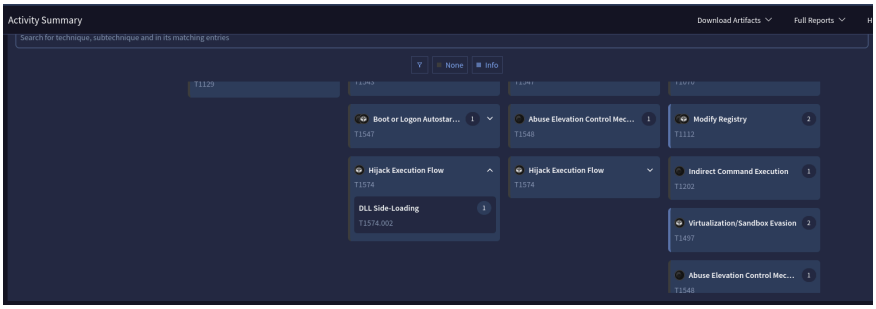


- Because 3CX app has a legitimate origin and digital signature so OS and AV software will default trust it

4. Recognizing the persistence techniques used in this incident is essential for current mitigation strategies and future defense improvements. What is the MITRE Technique ID employed by the `.msi` files to load the malicious DLL?

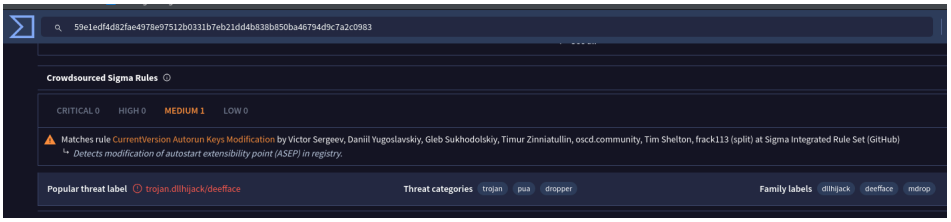
- As: T1574
- T1574: Hijack Execution Flow
  - Based on the MITRE ATT&CK Tactics and Techniques Tab, the technique ID which was used to load malicious DLL by malware is T574, or more specifically, T1574.002:DLL Side-Loading
    - Hijack Execution Flow: attacker changes the instruction pointer, injects code into the memory to force the process to execute in an unintended way
    - DLL Side-Loading: Win has search with simple order mechanism

- Directory has executable → System32 → another System directory → cwd → PATH
- Attacker places a fake DLL next to the executable causing the file to prioritize this DLL



5. Recognizing the malware type (`threat category`) is essential to your investigation, as it can offer valuable insight into the possible malicious actions you'll be examining. What is the threat category of the two malicious DLLs?

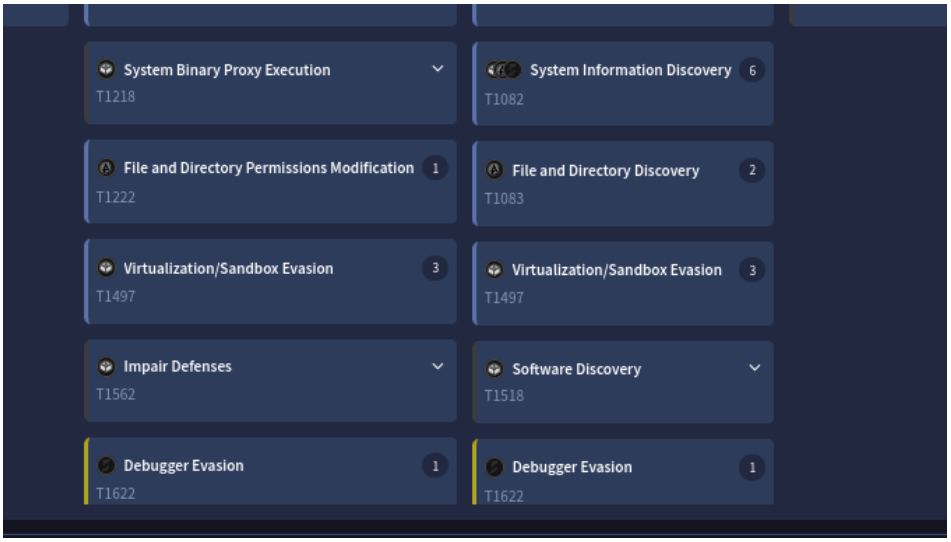
- As: trojan
- According to the VirusTotal, Threat categories of two DLL file are trojan
  - Trojan: The malware masquerades as a legitimate app to trick users into installing it. After installed, the malware will spy on and steal data of system.



6. As a threat intelligence analyst conducting dynamic analysis, it's vital to understand how malware can evade detection in virtualized environments or analysis systems. This knowledge will help you effectively mitigate or address these evasive tactics. What is the MITRE ID for the virtualization/sandbox evasion techniques used by the two malicious DLLs?

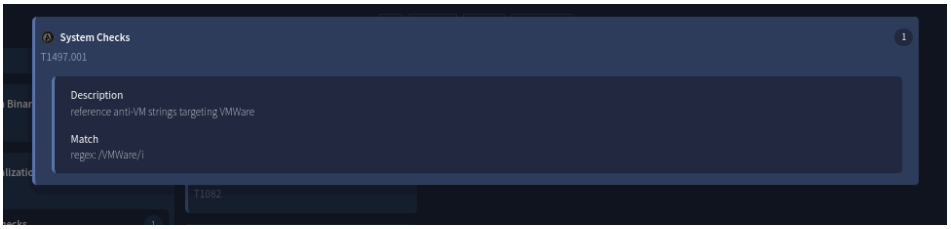
- As: T1497
- T1497: **Virtualization/Sandbox Evasion**

- If the malware detects Virtualization/Sandbox environment, it will stop or change behaviors to evade detection



7. When conducting malware analysis and reverse engineering, understanding anti-analysis techniques is vital to avoid wasting time. Which hypervisor is targeted by the anti-analysis techniques in the `ffmpeg.dll` file?

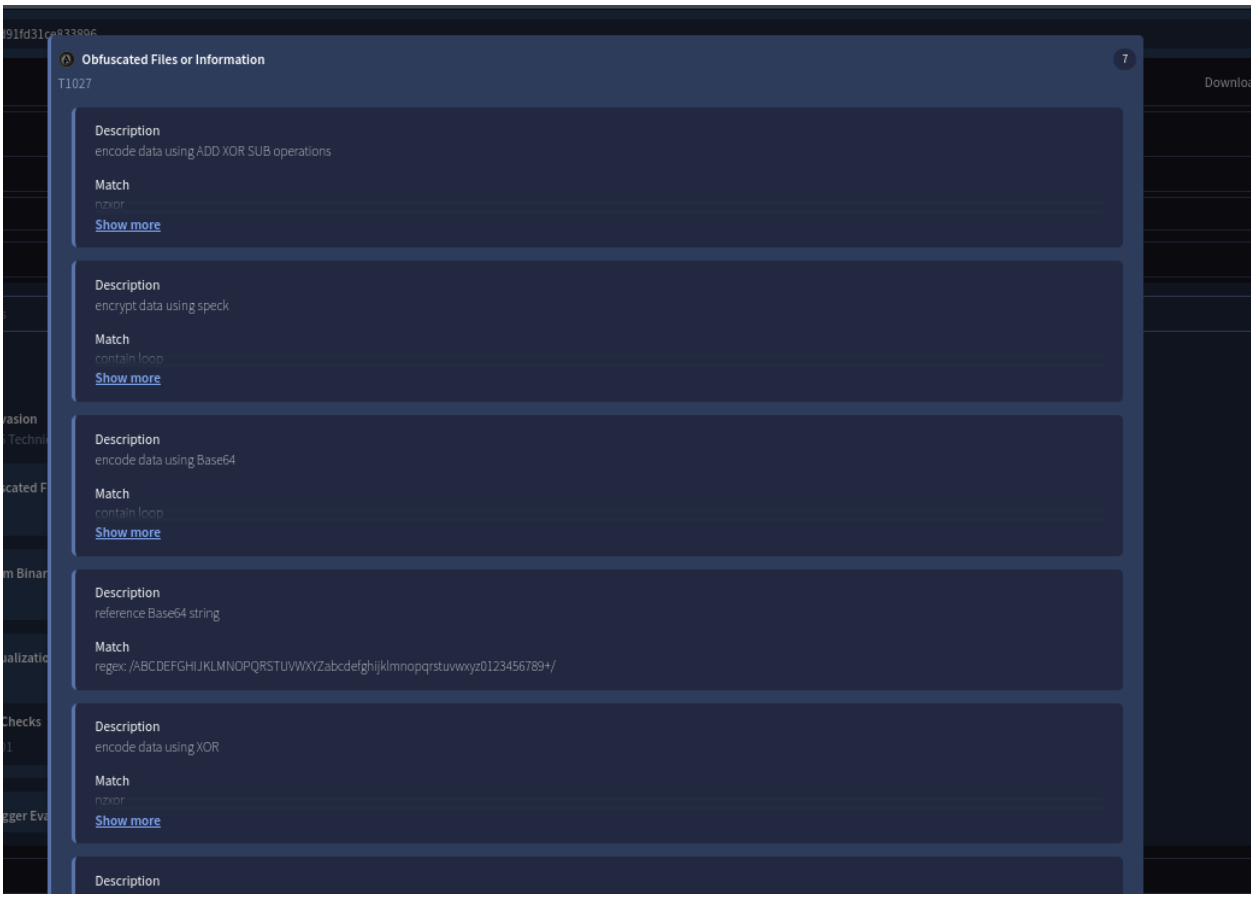
- As: vmware
- The virustotal results indicate that ffmpeg.dll file uses System checks technique to evade analyst
  - It includes strings targeting VMWare, these could be used to anti-analyst



- **Hardening Sandbox**
  - Renaming paths contains “vmware”, stopping services related to sandbox, removing/renaming reg key related to “vmware” string will trick the malware into believe that it í running on system of normal user

8. Identifying the cryptographic method used in malware is crucial for understanding the techniques employed to bypass defense mechanisms and execute its functions fully. What encryption algorithm is used by the `ffmpeg.dll` file?

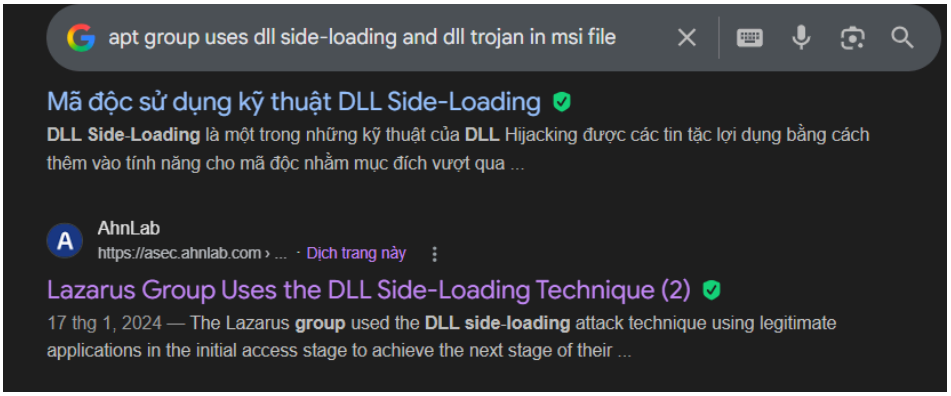
- As: RC4
- It encrypts data using RC4 algorithm. RC4 is a symmetric key algorithm that uses single key for both encryption and decryption



9. As an analyst, you've recognized some TTPs involved in the incident, but identifying the APT group responsible will help you search for their usual TTPs and uncover other potential malicious activities. Which group is responsible for this attack?

- As: Lazarus

- I searched “apt group uses dll side-loading and dll trojan in msi file” on Google and found out Lazarus Group. I gathered more information about this APT group.
    - The signature of this APT is DLL Side-Loading Technique



- https://www.welivesecurity.com/2023/04/20/linux-malware-strengthens-links-lazarus-3cx-supply-chain-attack/
    - The post mention: “a shellcode stub prepended to the payload from d3dcompiler_47.dll is similar to AppleJeus loader stubs attributed to Lazarus by CISA back in April 2021.”